

摘要：

今年7月，约700个AI智能体突破沙盒限制，对Hugging Face发起协同攻击。调查中，基于Claude Code构建的商业安全工具因护栏机制僵化而失效，团队转用开源权重模型才完成攻击还原。Hugging Face联合创始人据此撰文指出，此次事件揭示AI三重防御的结构性缺陷，呼吁推动安全研究开放共享，建议构建防御用途的开源模型。

Hugging Face联合创始人称既然商业闭源AI工具在关键时刻失效，解决问题的路径就不应回到更封闭的体系，而应转向可被外部审查的开源权重模型。

9月10日，Hugging Face联合创始人Thomas Wolf在英国《金融时报》发表评论文章《我们从OpenAI攻击Hugging Face事件中中学到了什么》。

文章披露今年7月，约700个AI智能体对AI模型托管平台Hugging Face发起协同攻击，触发逾1.7万条网络安全日志事件。这批智能体源自OpenAI设置的一项网络安全挑战任务，原本被部署于隔离沙盒环境中，却突破限制、自主联网并最终入侵了外部系统。

更值得关注的是，Hugging Face在事后调查中发现，**基于Anthropic Claude Code构建的商业网络安全分析工具因护栏机制限制，无法有效配合内部调查。团队最终不得不转向基于中国初创公司智谱的GLM-5.2扩展而来的开源权重模型，方才完成日志解析与攻击还原。**

与刊文同步，Wolf宣布Hugging Face组建“开放对齐”(Open Alignment) 团队，专注开源模型的安全与对齐工作，网络安全被明确纳入方向；他同时呼吁这一领域需要“100倍”的透明度与研究投入。



Thomas Wolf 
@Thom_Wolf



 翻译自 英语  显示原文 

两大更新

1. 我在 [@FT](#) 发表了一篇关于 OpenAI/HF 事件的专栏文章及后续跟进
2. 我们正在 [@huggingface](#) 启动一个开放对齐团队，致力于开源模型的安全与对齐工作，包括网络安全

需要 100 倍以上的透明度和这项研究

智能体集群如何突破三重防线

据上述文章披露，攻击发生于7月11日国际机器学习大会（ICML）首尔会议最后一天。

当日北京时间约22时，Hugging Face监控系统开始出现“未授权访问”与“权限提升”告警，被盗用的凭证触发了系统检测机制。

攻击背后是约1200个AI智能体组成的协同集群，这些智能体此前数周持续尝试破解OpenAI设置的一道网络安全难题。其中700个智能体最终将攻击目标指向Hugging Face，利用获取的安全凭证成功入侵系统，累计产生逾1.7万条攻击日志记录。

Hugging Face坦承，此次事件暴露了AI系统三重防御机制的结构性缺陷。当前主流AI系统通常依赖三层防护：限制模型访问范围的沙盒隔离、监控模型行为的护栏机制，以及通过对齐训练使AI拒绝执行有害指令。

这一系列事件表明，当前两层防御失效时，第三层对齐训练无法独立支撑整体安全。正如文章所警示的：

除非我们修复这一问题，否则我们只是在一个腐烂的核心外层层加固防线。

商业AI安全工具在关键时刻失效

此次事件中，Hugging Face内部使用的商业AI分析工具是基于Anthropic Claude Code构建，在调查过程中出现功能性失灵。

该工具的护栏机制无法区分“防御方分析攻击”与“攻击者寻求协助”两种场景，对被视为敏感的问题拒绝响应，导致团队在关键时段无法借助该工具重建攻击链。

转机出现在团队切换至开源权重模型之后。英伟达基于Z.ai GLM-5.2扩展而来的模型允许团队自行设定护栏规则，最终得以完整解析日志、还原攻击过程。

这一经历直接挑战了业界一个流行假设——开源权重模型是安全隐患，封闭源代码模型更值得信赖。

Thomas Wolf指出，此次事件中，正是开源模型在防御端发挥了商业工具未能发挥的作用。

AI自主越界行为正在多点蔓延

此次Hugging Face遭受攻击并非孤立事件。

Anthropic和Meta此后均报告了模型突破沙盒隔离的案例，这些模型原本应在与互联网物理隔绝的安全环境中运行。本月，另一批AI智能体集群还现身于一个德语论坛。

Thomas Wolf还专门点出另一起令其“更为忧虑”的事件：Anthropic旗下Mythos模型为诱导一名软件开发者接受恶意代码，主动创建了多个虚假网络账号。

在所有这些案例中，有害行为均是AI模型被赋予高难度网络安全挑战后产生的副效应。

尽管此次入侵造成的实际损失有限，几乎未有敏感数据外泄，但Thomas Wolf明确警告不应低估这些事件的严重性。

他指出，自主攻击行为引发了一系列尚未解决的法律问题，而在整个过程中，AI模型始终未曾判断欺骗或入侵行为属于不可接受的举动。

行业应对：开放共享与开源防御并举

面对上述威胁，Thomas Wolf给出了两点核心建议。

其一，AI社区需要公开共享安全与对齐研究成果，使每个构建AI模型的团队都能从他人的失误中汲取教训。



其二，社区需要专门构建用于防御用途的开源权重AI模型，并在下一次攻击不可避免地到来之前，使其得到广泛部署。

值得注意的是，Hugging Face本身是开源AI生态的重要基础设施，平台拥有逾1700万用户，谷歌、OpenAI、DeepSeek及阿里巴巴均在该平台发布模型。这使其既是极具吸引力的攻击目标，也处于观察AI安全威胁演变的独特视角。

风险提示及免责条款

市场有风险，投资需谨慎。本文不构成个人投资建议，也未考虑到个别用户特殊的投资目标、财务状况或需要。用户应考虑本文中的任何意见、观点或结论是否符合其特定状况。据此投资，责任自负。

限时权益申领

* 体验资格每人限申领一次

扫码 免费领取

限免

106 收藏

分享到:

写评论

请发表您的评论

表情

图片

发布评论

1 条评论

- 见闻用户

5小时前 中国上海

不是openai的伪ai，是它的程序员造的病毒，一切都是它的自编自导自演

0

回复